

Actividad grupal 3 – Auditoría de Sistemas

Luego de la evaluación de calidad realizada sobre el sistema web de gestión de turnos para un gimnasio, la organización detecta distintos problemas durante el uso inicial del sistema:

- usuarios con permisos excesivos
- registros incompletos de operaciones
- errores en algunos datos cargados
- ausencia de ciertos controles automáticos
- dificultades para identificar responsabilidades sobre determinadas acciones

Se desea realizar una auditoría del sistema de información y para ello deberán basarse en: el WBS y planificación definidos en la Actividad grupal 1 y las métricas y evaluación de calidad realizadas en la Actividad grupal 2.

A partir de esta información, deberán actuar como auditores y analizar el estado actual del sistema. Les pedimos:

a) Describan brevemente el sistema desarrollado, las funcionalidades principales, los usuarios involucrados y los activos críticos del sistema (consideren datos, software, documentación, personal, infraestructura).

El sistema desarrollado es una aplicación web de gestión de turnos para un gimnasio, construida en un plazo de 3 meses por un equipo de tres desarrolladores (un semi senior y dos juniors). Las funcionalidades principales son el registro de usuarios, la reserva de clases, la cancelación de reservas y la visualización de disponibilidad de horarios y cupos.

Los usuarios involucrados son dos tipos: los socios del gimnasio, quienes utilizan el sistema para gestionar sus turnos de forma autónoma, y el personal del gimnasio, que puede requerir acceso para tareas administrativas.

Los activos críticos del sistema son:

- **Datos:** la base de datos de usuarios registrados, las reservas activas y el registro de disponibilidad de clases.
- **Software:** el código fuente de la aplicación web, especialmente los módulos de reserva y cancelación, que constituyen el núcleo funcional del sistema.

- **Documentación:** el WBS, las historias de usuario, los casos de uso y los requisitos funcionales y no funcionales relevados, que son la base para el desarrollo y la verificación.
- **Personal:** los desarrolladores, los cuales concentran el conocimiento técnico del equipo y validan los resultados.
- **Infraestructura:** el servidor web y la base de datos en el entorno de producción.

b) Analicen cómo evaluarían si el sistema cumple con los objetivos de control interno. Relacionen cada objetivo con ejemplos concretos del sistema desarrollado.

1. Preservación de los activos

Se evaluaría verificando que el sistema proteja adecuadamente sus activos críticos: los datos de usuarios y reservas, el código fuente y la infraestructura, etc. En el sistema del gimnasio, esto implica controlar que exista autenticación para acceder al sistema, que solo usuarios registrados puedan realizar reservas o cancelaciones, y que no sea posible modificar o eliminar datos de otros usuarios. Un control concreto sería verificar que un socio no pueda cancelar la reserva de otro socio.

2. Integridad de los datos

Se evaluaría comprobando que los datos almacenados sean correctos, completos y consistentes. En el sistema, esto se relaciona directamente con los problemas detectados en la auditoría: la posibilidad de generar reservas duplicadas y de cancelar una reserva incorrecta son ambos fallos de integridad. Los controles a verificar incluyen que el sistema valide disponibilidad antes de confirmar una reserva, que no permita inscribir al mismo usuario dos veces en la misma clase, y que la cancelación opere únicamente sobre la reserva seleccionada por el usuario que la solicitó.

3. Eficacia en el logro de los objetivos organizacionales

Se evaluaría determinando si el sistema produce el impacto esperado en la operación del gimnasio. Los controles concretos incluirían verificar que los socios puedan autogestionar sus reservas sin necesidad de intervención del personal, que el sistema no permita que una clase supere su cupo máximo, y que la disponibilidad mostrada refleje en todo momento el estado real. Los problemas detectados en la auditoría, como reservas duplicadas o cancelaciones sobre turnos incorrectos, son evidencia directa de que este objetivo no se cumple plenamente.

4. Uso eficiente de los recursos

Se evaluaría midiendo el consumo real de recursos del sistema ante operaciones típicas. Por ejemplo, se analizaría cuántas consultas a la base de datos genera una reserva, cuánta memoria consume el servidor durante el procesamiento de operaciones concurrentes, o si existen consultas redundantes o mal optimizadas. El objetivo es determinar si los recursos de infraestructura se utilizan de forma proporcional a la complejidad de cada operación.

c) Identifiquen 2 riesgos relacionados con la pérdida o modificación de datos y 2 posibles abusos computacionales y clasifíquenlos.

Riesgos relacionados con la pérdida o modificación de datos:

1. **Inconsistencia al crear o cancelar reservas:** Debido a los problemas reportados directamente en las operaciones de alta y cancelación, existe el riesgo de que el sistema asigne un mismo cupo a dos personas o elimine accidentalmente un turno válido por una falla en la lógica de procesamiento de los datos.
 - **Clasificación:** Corrupción de software.
2. **Modificación irrecuperable por falta de trazabilidad:** Al haber registros incompletos y errores en los datos cargados, se corre el riesgo de que una modificación errónea sobre la información de un socio o sus turnos quede asentada de forma permanente, sin posibilidad de identificar qué pasó o cómo revertirlo.
 - **Clasificación:** Error de diseño operativo / Error humano.

Posibles abusos computacionales:

1. **Manipulación intencional de la agenda:** Al detectarse problemas con los niveles de acceso, un empleado o usuario administrativo podría aprovechar estos privilegios excesivos para cancelar el turno de un socio legítimo y cederle el lugar a un tercero por conveniencia personal, saltándose las reglas del gimnasio.
 - **Clasificación:** Abuso de privilegios.
2. **Vulneración de cuentas de usuarios:** A raíz de la ausencia de controles automáticos en el sistema de autenticación (Login), un atacante o usuario malintencionado podría forzar el acceso a la cuenta de otro socio mediante ataques simples (como probar contraseñas comunes) para robar información personal o sabotear sus reservas.
 - **Clasificación:** Hacking.

d) Seleccionen al menos 4 controles internos que deberían existir en el sistema. Para cada control expliquen cómo funcionaría e indiquen qué problema ayudaría a prevenir o detectar.

1. Documentos y registros (logs) adecuados

Toda operación de creación, modificación o eliminación (turnos, datos de socios) genera automáticamente un registro que contiene: identificador del usuario que ejecutó la acción, marca de tiempo exacta, estado anterior del dato y estado posterior. Este log no puede ser eliminado ni modificado por ningún rol, incluido el administrador.

Detecta quién realizó cada operación y cuándo, permitiendo identificar errores o manipulaciones. Además soluciona el problema de tener registros incompletos de operaciones.

2. Delegación clara de autoridad y responsabilidades

Cada usuario debe tener permisos y responsabilidades claramente definidos dentro del sistema. Se definen dos roles principales con permisos delimitados explícitamente: Socio (puede reservar, cancelar y consultar sus propios turnos únicamente, sin acceso a datos de otros socios ni a configuraciones del sistema) y Personal administrativo (puede gestionar reservas de todos los socios, consultar disponibilidad general y acceder a reportes de ocupación, pero no puede modificar la configuración del sistema ni eliminar cuentas de socios).

Resuelve el problema de dificultad para identificar responsabilidades, con roles claros, cada acción tiene un responsable predefinido.

3. Separación de obligaciones

Las tareas del sistema deben dividirse entre distintos usuarios. Por ejemplo, un usuario puede registrar reservas pero no modificar permisos ni eliminar registros del sistema.

Impide que un usuario con malas intenciones complete un abuso de forma autónoma. Soluciona el problema de usuarios con permisos excesivos.

4. Sistema de autorizaciones

Las operaciones sensibles deben requerir validaciones o permisos especiales. El sistema verifica que el usuario posea autorización explícita antes de ejecutar acciones críticas. Por ejemplo modificación de datos críticos, eliminación de reservas, cambios sobre disponibilidad de clases, acceso a reportes administrativos.

Soluciona los problemas de tener errores en datos cargados y la ausencia de controles automáticos.

e) Redacten al menos 2 hallazgos completos incluyendo: situación observada, problema detectado e impacto posible.

1. Sobreasignación de cupos por deficiencias en la concurrencia

Situación observada: Durante las pruebas y la revisión de los registros (logs) de la base de datos correspondientes al módulo de "Alta de reservas de clases", se evidenció que en múltiples ocasiones la cantidad de inscriptos a una clase superó el

límite máximo de cupos configurados para la misma (se encontró 21 personas registradas en una clase con cupo máximo de 20 personas).

Problema detectado: El sistema carece de un control de concurrencia adecuado (como bloqueos transaccionales) al momento de asignar un lugar. Cuando dos o más usuarios intentan reservar un turno exactamente al mismo tiempo y queda un solo cupo disponible, el sistema valida positivamente la disponibilidad para ambos antes de que el primero termine de guardar la transacción, permitiendo que ambos se inscriban exitosamente ocupando el mismo lugar.

Impacto posible: Riesgo operativo por superar la capacidad física del establecimiento. Además, genera un impacto negativo directo en la reputación del gimnasio y en la calidad del servicio al cliente, ya que los usuarios que asisten legítimamente con su reserva podrían quedarse sin espacio físico o equipamiento disponible para entrenar.

2. Inconsistencia de datos en la cancelación de reservas

Situación observada: Al auditar los procesos de cancelación de reserva de clases, se encontró que cuando un usuario cancela su asistencia a una clase, la acción aparece como exitosa en su pantalla, pero la capacidad disponible de la clase en el sistema no se incrementa.

Problema detectado: Existe un error en la lógica transaccional del módulo de cancelaciones. El sistema desliga la reserva del usuario, pero falla al actualizar el cupo correspondiente a la clase que se cancela la reserva dejando al sistema en un estado inconsistente.

Impacto posible: Pérdida de integridad en la información de disponibilidad y afectación a la experiencia del usuario. Se generan cupos desperdiciados, impidiendo que otros socios del gimnasio en lista de espera o interesados puedan reservar esos lugares. Esto conlleva ineficiencia en el uso de los recursos de la organización y frustración en usuarios que ven clases "llenas" en el sistema cuando hay lugar disponible.

f) Selecciones una decisión de planificación de la Actividad grupal 1 y una métrica de calidad de la Actividad grupal 2 y expliquen cómo se relacionan con los problemas encontrados durante la auditoría.

La decisión de planificación seleccionada es la estimación de la tarea "Implementar reserva de clases" con 80 horas de esfuerzo distribuidas en 10 días, lo que implica que un único desarrollador trabaje al 100% de su capacidad de forma ininterrumpida. Como se reconoció en la Actividad grupal 1, esta relación entre

esfuerzo y duración es logísticamente irreal, ya que no contempla interrupciones, imprevistos ni la posibilidad de error.

La consecuencia directa de esta planificación ajustada fue que la tarea no pudo completarse con el rigor necesario dentro del tiempo previsto. Esto se vincula con la métrica de completitud funcional definida en la Actividad grupal 2, donde se establece que el valor mínimo aceptable es 0,5, es decir, que puede quedar hasta una funcionalidad central sin implementar correctamente. Este umbral, que en su momento se justificó por tratarse de una primera versión, terminó habilitando que las funcionalidades de reserva y cancelación de reservas se entregaran con implementación deficiente.

Durante la auditoría, esto se manifestó concretamente en los problemas detectados: la posibilidad de generar reservas duplicadas para un mismo usuario o clase, y cancelaciones que afectan una reserva incorrecta. Ambos escenarios representan fallas de integridad de datos que impactan directamente en la operación del gimnasio.